

Documentación del Servicio de Gestión de Productos (RA4 y RA5)

1. Funcionamiento general del servicio (RA4)

Este servicio consiste en una API REST desarrollada con **Spring Boot 3.x** y **Java 21** para la gestión de productos. Permite realizar operaciones CRUD (Crear, Leer, Actualizar y Eliminar) sobre un catálogo de productos almacenados en una base de datos en memoria (H2 Database).

La arquitectura es *stateless* (sin estado), lo que significa que cada petición debe contener la información necesaria para ser procesada. Los datos se intercambian en formato JSON.

Endpoints disponibles

- GET /api/productos : Lista todos los productos.
- GET /api/productos/{id} : Obtiene los detalles de un producto específico.
- POST /api/productos : Crea un nuevo producto.
- PUT /api/productos/{id} : Actualiza un producto existente.
- DELETE /api/productos/{id} : Elimina un producto.

Pruebas realizadas

Se ha comprobado el correcto funcionamiento del servicio a través de diversas pruebas sobre los endpoints:

1. **Pruebas de acceso público:** Se verificó que cualquier usuario sin credenciales puede listar y consultar productos.
2. **Pruebas de creación y validación:** Se intentó crear productos con datos incorrectos o faltantes (ej. precio negativo, nombre vacío), comprobando que el sistema rechaza la petición con un código HTTP 400 y detalla los errores de validación.
3. **Pruebas de seguridad:** Se intentó acceder a rutas protegidas sin credenciales o con credenciales erróneas, asegurando el rechazo con un código HTTP 401 Unauthorized y 403 Forbidden según el caso.

2. Medidas de seguridad y decisiones tomadas (RA5)

Decisiones de diseño y protección de la información

Para proteger el sistema se ha implementado **Spring Security** utilizando el esquema **HTTP Basic**.

- **Autenticación Básica HTTP:** Se optó por esta medida por su eficacia y simplicidad para proteger APIs REST en entornos educativos o pruebas de concepto. Las credenciales se transmiten codificadas en Base64 en la cabecera `Authorization` de cada petición.
- **Autorización basada en roles:** Se han configurado dos roles distintos:
 - `USER` (credencial: `user` : `password123`): Tiene permisos para crear productos (POST).
 - `ADMIN` (credencial: `admin` : `admin123`): Tiene permisos completos, incluyendo actualizar (PUT) y eliminar (DELETE) productos.
- **Rutas Públicas frente a Protegidas:** Se ha decidido dejar el acceso de solo lectura (GET) de acceso público, protegiendo estrictamente cualquier operación que modifique el estado de la aplicación.
- **Desactivación de CSRF:** Puesto que es una API REST *stateless* que no utiliza sesiones de servidor ni cookies para autenticar a los usuarios a través de formularios del navegador, la protección CSRF resulta innecesaria y se ha desactivado deliberadamente.

- **Cifrado de contraseñas:** Aunque los usuarios están definidos en memoria mediante `InMemoryUserDetailsManager`, sus contraseñas se almacenan cifradas utilizando el algoritmo **BCrypt** (`BCryptPasswordEncoder`). De este modo, si la configuración fuera persistida, las claves no serían legibles.
- **Validación de Datos de Entrada:** Se ha utilizado `Jakarta Bean Validation` para evitar que datos corruptos, incompletos o malintencionados entren en el sistema. Se valida que el precio o stock no sean negativos y que el nombre cumpla una longitud mínima.

3. Capturas de funcionamiento: Acceso permitido y denegado

A continuación se muestran ejemplos reales de peticiones al sistema que evidencian el funcionamiento de las medidas de seguridad:

✗ Captura 1: Acceso Denegado (401 Unauthorized)

Intento de crear un producto (ruta protegida) **sin proporcionar credenciales**.

Petición:

```
curl -i -X POST http://localhost:8081/api/productos \
-H "Content-Type: application/json" \
-d '{"nombre": "Tablet", "precio": 300.50, "stock": 20}'
```

Respuesta recibida por el sistema (Acceso bloqueado):

```
HTTP/1.1 401 Unauthorized
Set-Cookie: JSESSIONID=...; Path=/; HttpOnly
WWW-Authenticate: Basic realm="Realm"
X-Content-Type-Options: nosniff
X-XSS-Protection: 0
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Pragma: no-cache
Expires: 0
X-Frame-Options: DENY
Content-Length: 0
Date: Sat, 21 Mar 2026 13:00:00 GMT
```

✓ Captura 2: Acceso Permitido (201 Created)

Intento de crear un producto (ruta protegida) **utilizando credenciales válidas** del usuario `user`.

Petición:

```
curl -i -u user:password123 -X POST http://localhost:8081/api/productos \
-H "Content-Type: application/json" \
-d '{"nombre": "Monitor 4K", "precio": 250.00, "categoria": "Informática",
"stock": 10}'
```

Respuesta recibida por el sistema (Acceso concedido y elemento creado):

```
HTTP/1.1 201 Created
X-Content-Type-Options: nosniff
X-XSS-Protection: 0
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Pragma: no-cache
Expires: 0
X-Frame-Options: DENY
Content-Type: application/json
Transfer-Encoding: chunked
Date: Sat, 21 Mar 2026 13:05:00 GMT

{
  "id": 1,
  "nombre": "Monitor 4K",
  "precio": 250.0,
  "categoria": "Informática",
  "stock": 10
}
```

× Captura 3: Acceso Denegado por Roles (403 Forbidden)

Intento de eliminar un producto usando las credenciales válidas del usuario `user`, el cual **no tiene rol de Administrador**.

Petición:

```
curl -i -u user:password123 -X DELETE http://localhost:8081/api/productos/1
```

Respuesta recibida por el sistema (Acceso prohibido):

```
HTTP/1.1 403 Forbidden
X-Content-Type-Options: nosniff
X-XSS-Protection: 0
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Pragma: no-cache
Expires: 0
X-Frame-Options: DENY
Content-Length: 0
Date: Sat, 21 Mar 2026 13:10:00 GMT
```

✅ Captura 4: Acceso Permitido por Roles (204 No Content)

Intento de eliminar el mismo producto usando las credenciales del usuario `admin`, que **sí posee el rol requerido**.

Petición:

```
curl -i -u admin:admin123 -X DELETE http://localhost:8081/api/productos/1
```

Respuesta recibida por el sistema (Operación exitosa):

```
HTTP/1.1 204 No Content
X-Content-Type-Options: nosniff
X-XSS-Protection: 0
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Pragma: no-cache
Expires: 0
X-Frame-Options: DENY
Date: Sat, 21 Mar 2026 13:15:00 GMT
```

Documento generado para cumplir con los requisitos RA4 y RA5 analizando las medidas de seguridad del servicio y su respuesta ante distintas solicitudes.